Studento — Data Privacy and Security Plan

Submitted to Great Neck Public Schools (the District) under New York Education Law §2-d, 8 NYCRR Part 121, and Board of Education Policies #8625 and #8635, as the contractor's data privacy and security plan to be attached to the District's Data Privacy Agreement.

Contractor: Moses Sasson, doing business as Studento **Contact for this plan:** studentoclockapp@gmail.com **Product:** Studento, iOS/iPadOS app (App Store id 6825547011) with an optional web version **Version of this plan:** 1.0, November 6, 2026. Verified against the released app and server code on that date.

1. What Studento is

A bell-schedule clock. It counts down to the next bell, shows the student's own class schedule, sends local bell reminders on the device, and offers small study tools (homework list, countdowns, notes, grade calculator). It works completely without an account. Nothing is required from the District: no roster, no SIS connection, no single sign-on, no student records.

2. Data inventory (what, why, where, how long)

2.1 On the device only (every user)

Class names, room numbers, chosen school and bell schedule, custom days, display settings, homework, countdowns, notes and grade percentages, all typed in by the student. Stored in the app's private sandbox on the device. Never transmitted unless the student signs in (2.2). Deleted when the student deletes the app, resets setup, or uses Back up & restore to move it.

2.2 On the Studento server (only students who choose to create an account)

Element	Purpose	Retention
Username (chosen by the student)	Sign in	Until the account is deleted
Password hash (PBKDF2-SHA256, 100,000 iterations, 16-byte random salt). The password itself is never stored or logged.	Sign in	Until the account is deleted
Session token hash, created and last-used timestamps	Keep the student signed in	Until sign-out or account deletion

Element	Purpose	Retention
The same schedule and settings as 2.1	Restore on another device	Until the account is deleted
Reports the student files about shared content (reason, free-text note, reporter's user id)	Content moderation	Until the admin resolves them

2.3 Transient (not stored)

- **Schedule reader (signed-in only, optional):** the photo or typed text of the schedule is sent over TLS to the Studento server, which forwards it to one AI provider to read the rows (Groq, Inc.; if unavailable, Google LLC's Gemini API; if unavailable, Cloudflare Workers AI). The server holds it in memory for that request only and does not write it to disk or database. The student reviews and confirms every row before anything is saved.
- **Rate limiting:** the requesting IP address is kept in a counter table for the length of the rate-limit window (minutes), then overwritten. It is never joined to an account.
- **Edge logs:** Cloudflare keeps standard HTTP request logs (no bodies) for its own short retention period.

2.4 Never collected

Legal name, email, phone, home address, date of birth, student ID number, grade level, school ID, location, contacts, calendar, photos of people (the reader expects a schedule document), advertising identifier, device identifier, analytics, crash telemetry, or any education record held by the District. Studento has no advertising, no analytics SDK and no third-party trackers (verified: the app's only network destinations are studento-app.pages.dev and Expo's update service).

2.5 Device permissions

Camera or Photo Library, asked only when the student taps "Scan my schedule". Notifications, asked for bell reminders (local notifications only; the push entitlement is removed at build time). Nothing else.

3. Where the data lives and who can reach it

- Server: Cloudflare Pages Functions and the D1 database, United States data centers.
- Subprocessors: Cloudflare, Inc. (hosting, database, Workers AI); Groq, Inc. and Google LLC (schedule reader, transient only); Expo / 650 Industries (app update files only, no user data); Apple Inc. (App Store distribution). No subprocessor receives anything that identifies the student.

- Access: one administrator account (the developer). It can read usernames, resolve reports, remove shared schools or schedules, and turn sign-ups, sharing or the reader off. There is no support tooling that exposes a student's saved schedule, and no one else has database access.

4. Security measures (aligned to the NIST Cybersecurity Framework, 8 NYCRR §121.5)

Identify. This document is the data inventory and is re-verified at each release. The server is a single codebase in a public repository (github.com/theprojectmaker/studento-ios) so the District can inspect it.

Protect. TLS 1.2+ for every connection (HTTP is not served). Data at rest encrypted by Cloudflare D1. Passwords hashed with PBKDF2-SHA256 and a per-user salt; tokens stored only as SHA-256 hashes; tokens on the device kept in the iOS Keychain. Rate limits on sign-up, sign-in, the reader and reports. Input validation on every endpoint; schedule times are checked for order and overlap. Least privilege: one admin, no shared credentials, API secrets held as Cloudflare encrypted secrets and never in source. Dependencies updated and checked at each release.

Detect. Cloudflare's edge protections (DDoS, bot management) in front of the service. Admin review of all content reports. Anomalous sign-up or request volume is visible in the Cloudflare dashboard and triggers the kill switches in 3.

Respond. See section 5.

Recover. The server holds nothing a student cannot re-enter in a minute; the app works offline and keeps its own copy. D1 provides point-in-time recovery for 30 days.

5. Incident and breach response (Education Law §2-d(6), 8 NYCRR §121.10, Policy #8635)

1. On discovering any unauthorized access to or release of student data, the contractor contains it immediately (revoke tokens, rotate secrets, disable the affected endpoint or the whole account system via the kill switch).
2. The contractor notifies the District's Data Protection Officer, Joseph Cangialosi (jcangialosi@greatneck.k12.ny.us), in the most expedient way possible and without unreasonable delay, and in every case within **seven (7) calendar days** of discovery, with: what happened, what data and roughly how many accounts, what has been done, and a contact.
3. The contractor cooperates with the District's own notifications to parents and to the NYSED Chief Privacy Officer, and bears its own costs of doing so.

4. A written post-incident report follows within 30 days.

6. Student and parent rights

- Everything a student entered is visible and editable in the app.
- Account deletion is in the app (Settings > Account > Delete my account) and removes the user row, tokens and saved data in one transaction, immediately.
- A parent or the District may request correction or deletion by email; answered within 10 business days.
- Complaints about privacy may go to the District's Data Protection Officer or to NYSED (privacy@mail.nysed.gov, 518-474-0937), as described in the Parents' Bill of Rights supplement.

7. Use limits

Student data is used only to provide the features above. It is never sold, used for marketing or advertising, used to build a profile, shared with any party except the subprocessors in section 3 for the stated purpose, or used to train AI models by the contractor. The contractor will not attempt to re-identify de-identified data.

8. Training and staff

The sole person with server access (the developer) has completed data privacy and security training covering Education Law §2-d, Part 121, FERPA and COPPA, and repeats it annually. There are no other employees or contractors with access.

9. End of agreement

When the District's agreement ends, or on request, the contractor deletes every account created by District students within 30 days and confirms in writing. Students may also delete their own accounts at any time.

10. Changes

Any material change to the data collected, the subprocessors or the security measures above will be sent to the District's Data Protection Officer before it takes effect, with an updated version of this plan.

Signed: _____ Date: _____ Moses Sasson, Studento